

SOC — Security Operations Center

What is it?

- A SOC is basically a **24/7 watch room** for a company's computer systems
- A team of people constantly watching for **cyberattacks, suspicious activity, and threats**
- Their job = detect the problem → analyze it → respond to it

Easy way to remember it

Think of the SOC like a hospital Emergency Room (ER)

Alerts come in like patients. Analysts are the nurses/doctors. Some alerts are minor (false alarms), some are real emergencies. Their job is to figure out which is which — fast.

The 3 things that make a SOC work

All three must work together. If one is weak, the whole SOC suffers.

People

The analysts, engineers, managers. Humans who can think and adapt when tools can't.

Process

Written step-by-step playbooks so every person handles every alert the same way. Nothing gets skipped.

Technology

The software tools they use — SIEM, EDR, SOAR, etc. Important, but only as good as the people using them.

Note to self

Technology is the **LEAST** important of the three on its own. The best tool in the world is useless if people don't know how to use it or there's no process to follow.

4 types of SOC

Depends on the company's size and budget.

In-house SOC

Company builds and runs its own team, in its own building. Full control. Most expensive. Needs constant budget to pay staff 24/7.

Virtual SOC

No physical building. Team works remotely from different locations. More flexible and cheaper.

Co-Managed SOC

Your internal team + an outside security company (called an MSSP) working together. Good middle ground. Coordination between both sides is critical.

Command SOC

A big SOC that manages multiple smaller SOC's across a region. Used by telecoms companies and military/defense organizations.

Memory trick: your house → shared house → no house → manages the whole street

SOC roles — who does what

SOC Analyst L1 / L2 / L3

First person to look at every alert. Classifies it (real threat or false alarm?), finds the cause, recommends how to fix it. L1 = basic triage. L2 = deeper investigation. L3 = the hardest cases.

Needs to know: Windows/Linux OS Networking Malware analysis

Incident Responder First responder

Steps in when an alert becomes a confirmed breach. Does the initial damage assessment — like a paramedic arriving at the scene first.

Threat Hunter Proactive

Doesn't wait for alerts. Goes out looking for threats hiding in the network that automated tools missed. Thinks like an attacker to find them first.

Security Engineer Builds the tools

Maintains and connects all the security software (SIEM, SOAR, etc.). If the analyst drives the car, the engineer built and maintains it.

SOC Manager Management

Handles budget, strategy, staffing, and keeps operations running. Deals with business side, not technical. Trusts the team for the technical stuff.

The 5 tools every analyst uses

SIEM — the alarm system

→ Collects logs from every system in the company and watches for suspicious patterns

→ When something crosses a threshold (like 20 failed logins in 10 sec) → fires an **alert**

→ The analyst's job starts here. A SIEM alert is a question, not an answer

Examples: Splunk, IBM QRadar, ArcSight, FortiSIEM

Log management — the search engine

→ All logs from all devices in one place. Search once instead of asking every device separately

→ Use case: malware found talking to IP 122.194.229.59 → search log mgmt to see if **any other device** talked to that same IP

EDR — the microscope on devices

→ Endpoint Detection & Response. Lives on every computer/device (called an endpoint)

→ Shows: running processes, network connections, browser history — everything happening on that device

→ **Containment feature** = isolate a hacked machine from the network while still being able to investigate it

Examples: CrowdStrike, SentinelOne, CarbonBlack, FireEye HX

SOAR — the automation layer

→ Security Orchestration, Automation & Response

→ Connects all your tools and runs automatic tasks when an alert fires (e.g. auto-checks IP on VirusTotal before analyst even opens it)

→ Uses **playbooks** — step-by-step checklists so every analyst investigates every alert the same way

Examples: Splunk Phantom, IBM Resilient, Demisto

Threat intelligence feeds — the case files

→ Lists of known-bad IPs, domains, and file hashes collected from past attacks worldwide

→ You check these to see if an IP or file you found was used in past attacks

Free sources: VirusTotal, Talos Intelligence

IPs can change owners! An IP flagged as malicious 2 months ago might now belong to someone's personal blog. Always re-check, don't assume.

Common mistakes — memorize these

These are the exact mistakes that make experienced analysts look careless. Know them before your first day.

Mistake 1 — Trusting VirusTotal blindly

Green result does NOT = safe. New malware uses techniques to bypass antivirus detection. VT is a helper, not the final word. Always do your own analysis too.

Mistake 2 — Short sandbox analysis (3–4 min)

Some malware detects it's being watched in a sandbox and stays completely inactive. Some waits 10–15 min before activating. Run analysis as long as possible, in a real environment if you can.

Mistake 3 — Only checking the device that triggered the alert

If one machine is infected and talking to a bad IP — others might be doing the same thing silently. Always search Log Management and EDR across ALL devices for the same indicator.

Mistake 4 — Looking at cached VirusTotal results

Attackers can put a clean URL on VT first (gets cached as safe), then swap it for a malicious site. Always force a fresh scan — look at the scan DATE, not just the result.

The rule that covers all 4 mistakes

Never trust one tool or one data point alone. Always ask: "what else could be true here that I haven't checked yet?"